

Cloud Forensics

<http://null.co.in/>

.....the State as on Date

The logo consists of the letters 'n|u' in a white, sans-serif font, centered on a solid blue rectangular background.

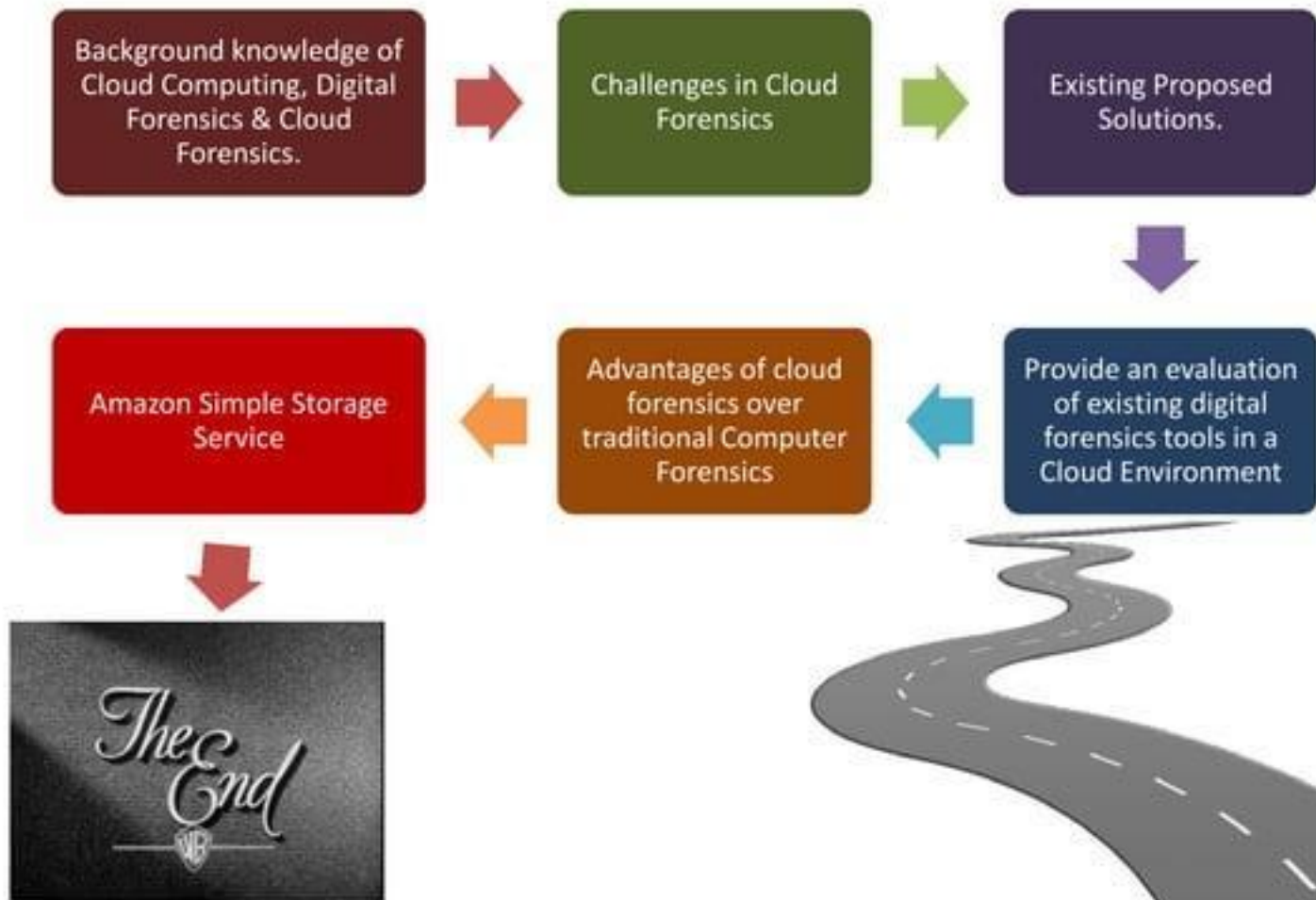
27 Apr 2013 ,Delhi Chapter

By : Anupam Tiwari



Forensics

a study of cloud services and their forensic capabilities



...the route

SECTION

1



Background knowledge of Cloud Computing, Digital Forensics & Cloud Forensics.



Forensics

a study of cloud services and their forensic capabilities



Service Models



- *SaaS*
- *PaaS*
- *IaaS*



- *Private*
- *Public*
- *Community*
- *Hybrid*



Deployment Models



Essential Services



- *On-demand self service*
- *Broad network access*
- *Resource pooling*
- *Rapid elasticity*
- *Measured service*

The DF as Defined by NIST

Definition of Digital Forensics

“The use of scientifically derived and proven methods toward the preservation, collection, validation, identification, analysis, interprétation, documentation, and preservation of digital evidence derived from digital sources for the purpose of facilitating or furthering the reconstruction of events found to be criminal, or helping to anticipate unauthorized actions shown to be disruptive to planned operations.”

--- DFRWS 2001



CLOUD FORENSICS as Defined by NIST

Definition of Cloud Forensics

Cloud forensics is the application of digital forensics science in cloud computing environments. Technically, it consists of a hybrid forensic approach (e.g., remote, virtual, network, live, large-scale, thin-client, thick-client) towards the generation of digital evidence. Organizationally, it involves interactions among cloud actors (i.e., cloud provider, cloud consumer, cloud broker, cloud carrier, cloud auditor) for the purpose of facilitating both internal and external investigations. Legally it often implies multi-jurisdictional and multi-tenant situations.



Traditional Route

Computer Forensics Process Flow





A Manager Says,
"GO"



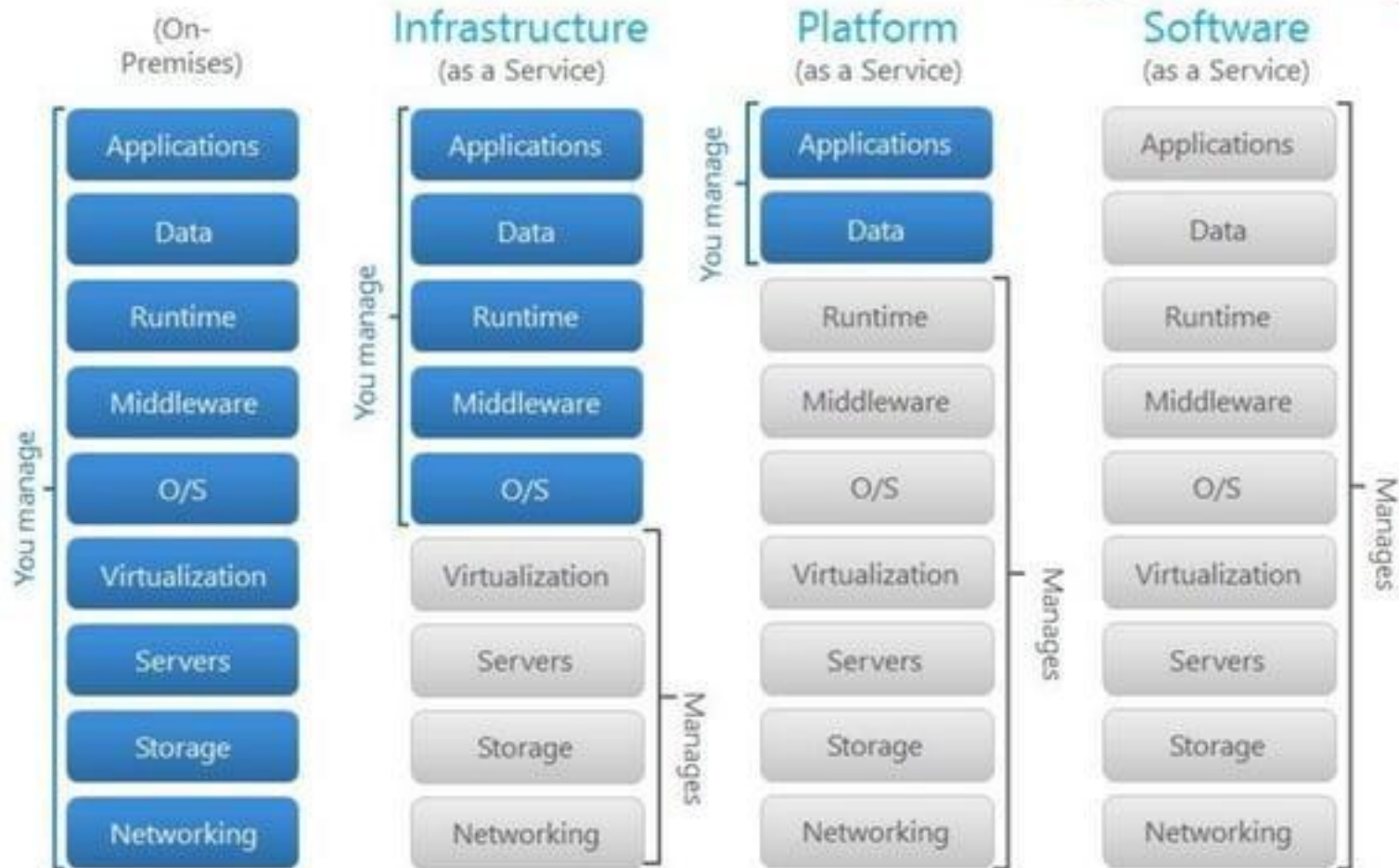
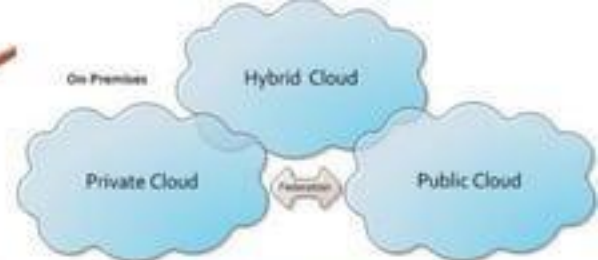
A Leader Says, "Let's Go"

Cloud	Forensics
Location independence	Discovery of computational structure Legal jurisdiction
Rapid elasticity	Evidence preservation Data integrity
Data reliability (replication)	Chain of custody Evidence integrity
Multi-tenancy	Attribution of data Chain of custody
General, abstract data structures	Best evidence Presentation/Visualization of evidence

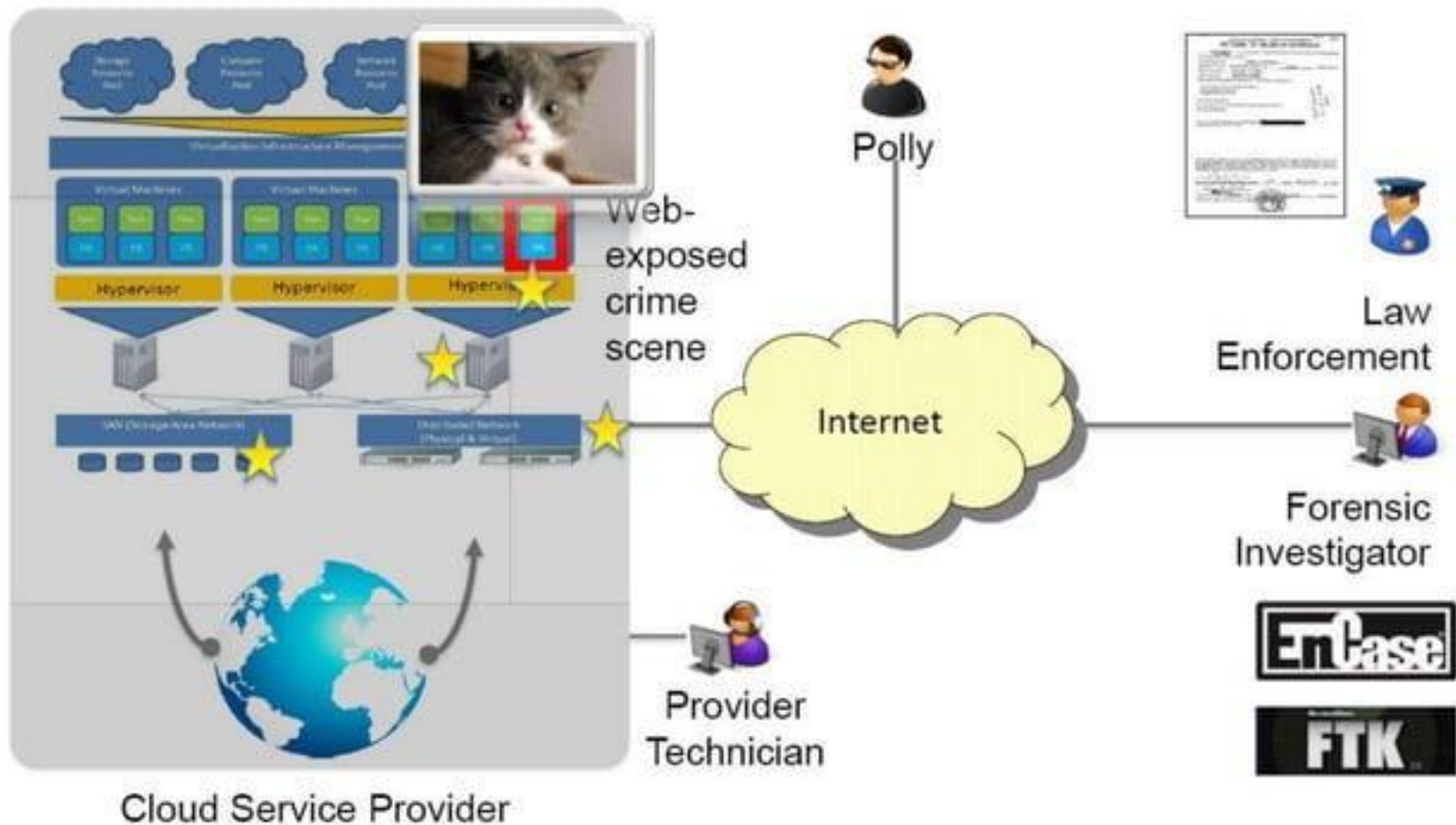


CONFLICTING GOALS

CONTROL FACTOR



Cloud Crime Scene



FIRST CLOUD CRIME



First Cloud Crime?

Amazon's EC2 Cloud Service Fueled PlayStation Network Attack



By David Murphy

May 14, 2011 03:23pm EST



7 Comments



Email



Print



0



Share

123

Tweet



Share

16

1

Digg



If you're looking for the source of the network attacks that brought down Sony's PlayStation Network—yes, it's still down—look no further than Amazon. The online retail giant didn't bring down the PlayStation Network per se, but an undisclosed source speaking to Bloomberg News has indicated that hackers used Amazon's cloud services to fuel the break-in.

According to the source, the hackers posed as a normal business and signed up for a legitimate server rental through Amazon's EC2 service—otherwise known as Amazon Elastic Compute Cloud. It's unclear how the hackers specifically used EC2 to push the attack out, which is almost as unknown a figure as the exact treasure trove of data the attackers were able to access within Sony's network.

CHALLENGES

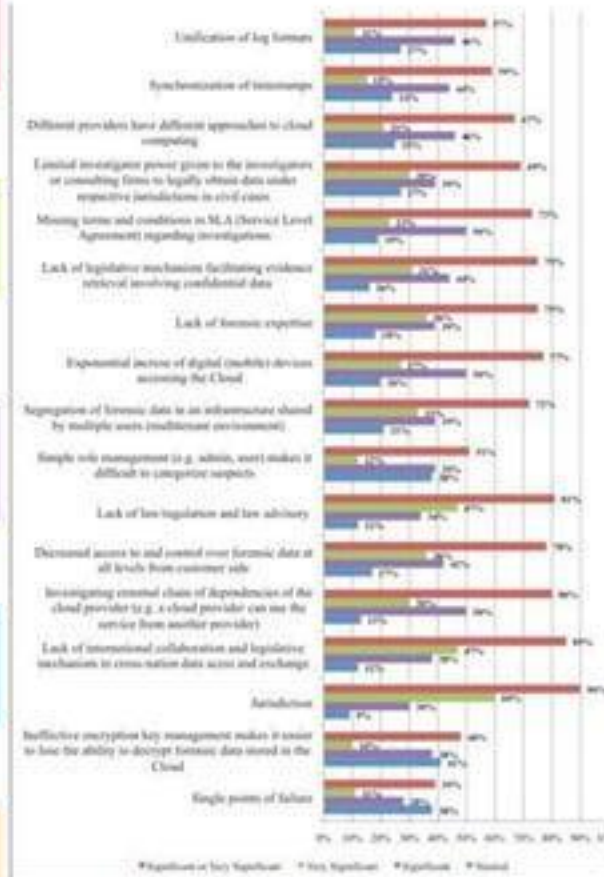
Storage system is no longer local.

Each cloud server contains files from many users.

Even if data belonging to a particular suspect is identified, separating it from other users' data is difficult.

Other than the CSP, there is usually no evidence that links a given data file to a particular suspect.

Healthcare, business, or national security related data!!!



VOLATILE DATA

Though with extra payment customers can get persistent storage, this is not common for small or medium scale business organizations.

A malicious user can exploit this vulnerability.

Some owner of a cloud instance can fraudulently claim that her instance was compromised by someone else and had launched a malicious activity. Later, it will be difficult to prove her claim as false by a forensic investigation .



Persistence in computer science refers to the characteristic of state that outlives the process that created it. Without this capability, state would only exist in RAM, and would be lost when this RAM loses power, such as a computer shutdown

Amazon S3

Q: Where is my data stored?

Amazon S3 offers storage in the US Standard, US West (Oregon), US West (Northern California), EU (Ireland), Asia Pacific (Singapore), Asia Pacific (Tokyo), South America (Sao Paulo), and AWS GovCloud (US) Regions. You specify a Region when you create your Amazon S3 bucket. Within that Region, your objects are redundantly stored on multiple devices across multiple facilities.

Microsoft Azure

Location of Customer Data

Microsoft may transfer Customer Data within a major geographic region (e.g., within Europe) for data redundancy or other purposes. For example, Windows Azure Storage geo-replication feature will replicate Windows Azure Blob and Table data, at no additional cost, between two sub-regions within the same major region for enhanced data durability in case of a major data center disaster. However, customers can choose to disable this feature.



MULTI-TENANCY

In cloud computing, multiple VM can share the same physical infrastructure, i.e., data for multiple customers may be co-located. This nature of clouds is different from the traditional single owner computer system.



issues can arise.

MULTI-TENANCY

First, How to prove that data were not comingled with other users' data ?

Secondly, How to preserve the privacy of other tenants while performing an investigation ?

Both of these issues also brings the **Side-Channel Attacks** that are difficult to investigate.

SIDE-CHANNEL ATTACKS

“ Using the Amazon EC2 service as a case study, we show that it is possible to map the internal cloud infrastructure, identify where a particular target VM is likely to reside, and then instantiate new VMs until one is placed co-resident with the target. We explore how such placement can then be used to mount cross-VM side-channel attacks to extract information from a target VM on the same machine.”

Source : <http://cloudsecurity.org/blog/2009/08/31/cloud-cartography-side-channel-attacks.html>

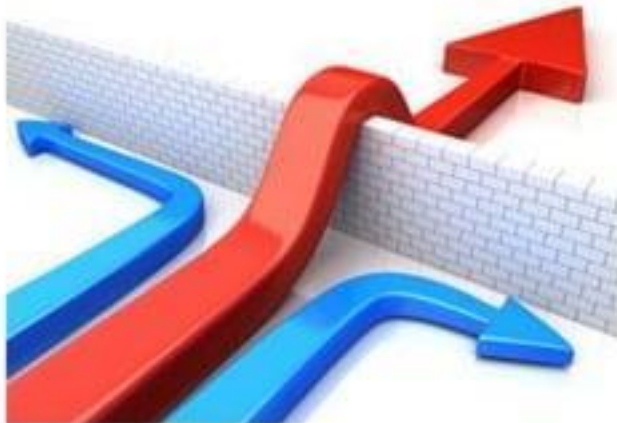
LOGGING

Analyzing logs from different processes plays a vital role in digital forensic investigation. Process logs, network logs, and application logs are really useful to identify a malicious user.

Not as simple as it is in privately owned computer system,

Sometimes even impossible.

Challenges :



Decentralization.

Volatility of Logs.

Multiple Tiers and Layers.

Accessibility of Logs.

Dependence on the CSP.

Absence of Critical Information in Logs.

Digital Chain of Custody
Must Span Operating Environments

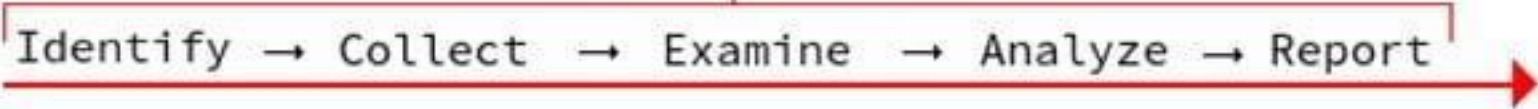


CHAIN OF CUSTODY



Evidence integrity
Chain of custody

Identify → Collect → Examine → Analyze → Report



- **CRIME SCENE RECONSTRUCTION**

- **CROSS BORDER LAW**

- **TRUSTWORTHY DATA RETENTION**

For example, who enforces the retention policy in the cloud, and how are exceptions, such as, litigation holds managed? Moreover, how can the CSPs assure us that they do not retain data after destruction of it .There are several laws in different countries, which mandate the trustworthy data retention. Just in United States, there are 10,000 laws at the federal and state levels that force the organizations to manage records securely. Some of the laws and regulations are stated below:

- ✓ **Sarbanes-Oxley Act**
- ✓ **The Health Insurance Portability and Accountability Act (HIPAA)**
- ✓ **The Securities and Exchange Commission (SEC) rule**
- ✓ **Federal Information Security Management Act**
- ✓ **The Gramm-Leach-Bliley**
- ✓ **European Commission data protection legislation**

Limitations of Current Forensic Tools

Due to the distributed and elastic characteristic of cloud computing, the available forensic tools cannot cope up with this environment.

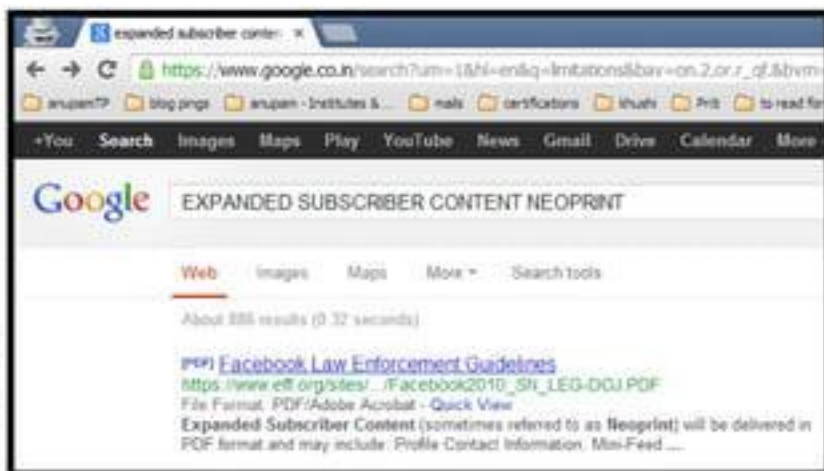
Tools and procedures are yet to be developed for investigations in virtualized environment, especially on hypervisor level.

Need of **FORENSIC AWARE** tools for the CSP and the clients to collect forensic data.

“Forensics” Today

Expanded Subscriber Content (sometimes referred to as Neoprint) will be delivered in PDF format and may include:

- Profile Contact Information
- Mini-Feed
- Status Update History
- Shares
- Notes
- Wall Postings
- Friend Listing, with Friends Facebook ID's
- Groups Listing, with Facebook Group ID's
- Future and Past Events
- Video Listing, with filename



User Photos (sometimes referred to as User Photoprint) is delivered in PDF format and may include photos uploaded by the user and photos uploaded by other users that have the requested user tagged in them.



PROPOSED

CURRENT SOLUTIONS

"EASIER SAID THAN DONE"



everything
is easier SAID
than done

except for talking

that's about
the same

INTEGRITY PRESERVATION

Generating a digital signature on the collected evidence and then checking the signature later is one way to validate the integrity. As data is distributed among multiple servers, this procedure is not simple, rather quite complicated.

A distributed **SIGNATURE DETECTION FRAMEWORK** that will facilitate the forensic investigation in Cloud environment.

Detection Framework



DISTRIBUTED SIGNATURE DETECTION FRAMEWORK

Current model of file storage comprises of two components – **Meta data Servers** (MDS) and **Object Storage Devices** (OSD). The hash value of each file is stored in the MDS as an e-tag and integrity is checked each time after uploading / downloading a file. In the proposed framework,

First step is to send a list of target buckets to the Forensic Cluster Controller (FCC), along with a file containing the target MD5 hash values. The FCC then initializes and queries to Analysis Nodes (AN) for getting the number of files contained in targeted bucket. Upon receiving the round one signature file from FCC, each AN retrieves the e-tags of the bucket. **Second Step**, the signatures in the round one signature file are compared with the signatures generated from the etags by the AN. After getting feedback from all ANs, FCC terminates the ANs. They tested their framework by two ways – using Amazon S3 and by emulating a cloud platform. **They achieved zero false positive and false negative rate and found significant improvement in terms of data required.**



CLOUD MANAGEMENT PLANE

Data acquisition is a challenging step in cloud forensics.

CSPs can play a vital role in this step by **providing a web based management console like AWS management console.**

From the console panel, customers as well as investigators can collect VM image, network, process, database logs, and other digital evidence, which cannot be collected in other ways.

Only problem with this solution is that, **it requires an extra level of trust – trust in the management plane.**



SOLUTION OF LEGAL ISSUES

At present, there is a massive gap in the existing Service Level Agreement (SLA), which neither defines the responsibility of CSPs at the time of some malicious incident, nor their role in forensic investigation.

Researches have given emphasis on sound and robust SLA between cloud service providers and customers.

A robust SLA should state *how the providers deal with the cyber crimes, i.e., how and to which extent they help in forensic investigation procedure*. In this context, another question can come – *how we can be sure of the robustness of a SLA*.

To overcome the cross border legislation challenges, **It is proposed that an international unity for introducing an international legislation for cloud forensics investigation**



VIRTUAL MACHINE INTROSPECTION

Virtual Machine Introspection (VMI) is the process of externally monitoring the runtime state of VM from either the Virtual Machine Monitor (VMM), or from some virtual machine other than the one being examined.

By runtime state, we are referring to processor registers, memory, disk, network, and other hardware-level events.

Through this process, we can execute a live forensic analysis of the system, while keeping the target system unchanged.

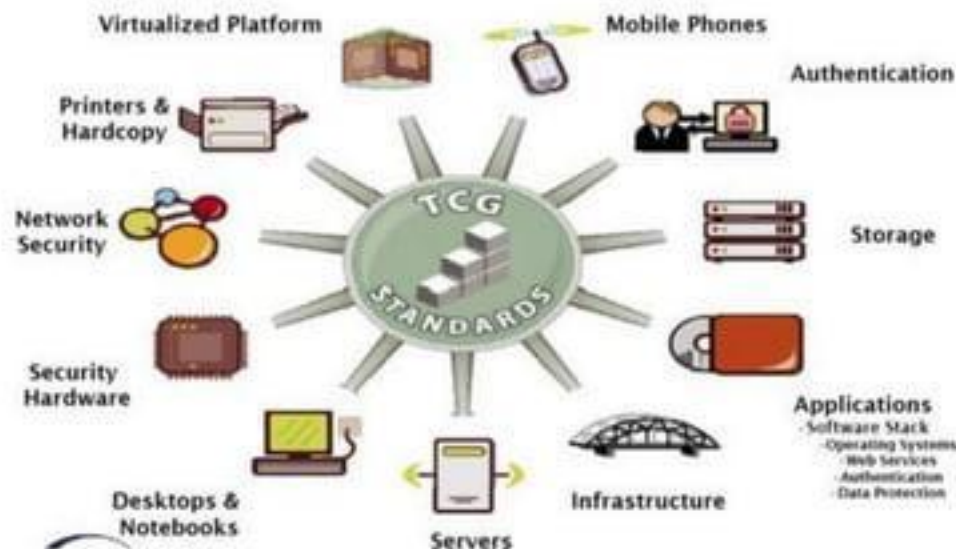
VIRTUAL MACHINE®



INTROSPECTION

The ability to look deep inside your mind's eye to find nothing but a clogged toilet full of crap.

TRUSTED PLATFORM MODULE (TPM)



By using TPM, we can get machine authentication, hardware encryption, signing, secure key storage, and attestation.

It can provide the integrity of the running virtual instance, trusted log files, and trusted deletion of data to customers.

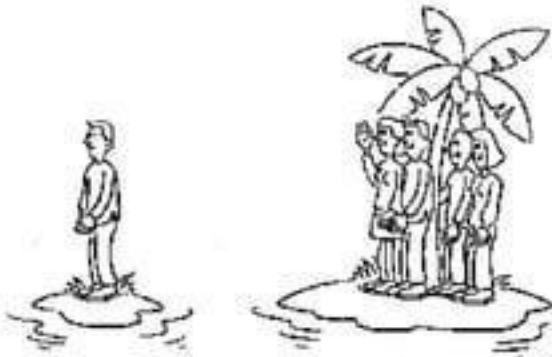
Moreover, at present, CSPs have heterogeneous hardware and few of them have TPM. Hence, CSPs cannot ensure a homogeneous hardware environment with TPM in near future.

ISOLATING A CLOUD INSTANCE



A cloud instance must be isolated if any incident take place on that instance. Isolation is necessary because it helps to protect evidence from contamination. However, as multiple instances can be located in one node, this task becomes challenging.

Moving a suspicious instance from one node to another node may result in possible loss of evidence.



To protect evidence, we can move other instances reside in the same node.

Provenance in Clouds

- Cloud provenance can be
 - **Data provenance**: Who created, modified, deleted data stored in a cloud (external entities change data)
 - **Process provenance**: What happened to data once it was inside the cloud (internal entities change data)
- Cloud provenance should give a **record** of who accessed the data at different times
- Auditors should be able to **trace** an entry (and associated modification) back to the creator

CURRENT WORK

Cybercrime and Cloud Forensics: Applications for Investigation Processes, IGI Global, 2013 (edited book)

Cloud Forensic Reference Architecture (CFRA)

Cloud Forensic Maturity Model (CFMM)

UCD CCI: Cloud Forensic Capability and Requirement Study for EU Law Enforcement

NIST Cloud Computing Forensic Science Working Group

CSA Cloud Forensics and Incident Management Working Group



CAN YOU PREPARE FOR CLOUD FORENSICS?

The key to avoiding much of this pain is being prepared before an incident occurs.

Once you become a customer, you have lost much of your leverage.....

Some of the things you should consider negotiating:

The provider will notify you immediately if there is any type of breach on the provider's system since it may impact your data.

The provider will allow you to access to the servers or system so you can self-collect.

Determine what type of data the provider collects, how long the provider holds it, and if the provider will store this data for you for a longer period of time.

Determine if the provider actually owns and controls the servers.

Write a business continuity/disaster recovery plan.

Determine where—in what state, states, or country—your data will be stored so you can determine which laws may apply.

EVALUATION OF CURRENT FORENSIC TOOLS IN CLOUD

Proven digital forensics tools used by forensic investigators :

Encase

Accessdata FTK

Fast Dump from HBGary

Memorysze from Mandia



EVALUATION OF CURRENT FORENSIC TOOLS IN CLOUD

Three experiments and data collected from three different layers and got success in all the experiments.

In the first experiment, they collected forensic data remotely from the guest OS layer of cloud. Encase Servlets and FTK Agents are the remote programs, which were used to communicate and collect data.

For the second experiment, they prepared an Eucalyptus cloud platform and collected data from the virtualization layer.

In the third experiment, they tested the acquisition at the host operating system layer by Amazon's export feature.

***Source : Acquiring Forensic Evidence from Infrastructure-as-a-Service
Cloud Computing: Exploring and Evaluating Tools, Trust, and Techniques***

EXTRACTING DATA FROM AMAZON EC2

Amazon stores virtual hard drives, called Elastic Block Storage (EBS) volumes, in its Simple Storage Service (S3), but they are not exposed to the end user for downloading.

Two options exist to obtain the data for an entire volume. The first is to create a snapshot from a drive being investigated, create a volume from that snapshot, attach the new volume read-only to a trusted Linux instance in EC2, and then create an ISO disk image of the volume that could be downloaded. The second is to detach the target volume from the host under investigation, attach it to a trusted Linux instance in EC2, and use a low-level copying utility (*e.g.*, the Unix data duplication tool *dd*) to create a block copy which can be stored in S3 and downloaded.

Amazon provides a service to export data from S3 onto a physical device and ship it to the requestor, but the customer must provide the storage device and is billed \$80 per storage device handled plus \$2.49 per data-loading-hour (Amazon Web Services, 2011).

Amazon provides a service to export data from S3 onto a physical device and ship it to the requestor, but the customer must provide the storage device and is billed \$80 per storage device handled plus \$2.49 per data-loading-hour (Amazon Web Services, 2011).

In neither of these cases is it possible to verify the integrity of the forensic disk image. Amazon does not provide checksums of volumes as they exist in their cloud, so one cannot positively assert that the image retrieved is identical to the original.

- Cloud computing can reduce the time for data acquisition, data copying, transferring and data cryptanalysis.
- Forensic image verification time reduced if cloud application generates cryptographic hash.
- Cost effectiveness
- Data abundance
- Overall robustness
- Scalability
- Flexibility
- Standards and Policies
- Forensics-as-a Service - Customers do not need to implement any forensic schemes.

advantage





- IaaS assumed

- In this service model, the provider has responsibility and access to only the physical hardware, storage, servers and network components.
- In the public interest, law enforcement first contacts the cloud provider with a temporary restraining order to suspend the offending service and account, and a preservation letter to preserve evidence pending a warrant.
- Tracking down the user is the more difficult task. The onus in this case is on the forensic examiner to piece together a circumstantial case based on the data available.

- The examiner **has no way to image the virtual machine** remotely since the cloud provider does not expose that functionality
- and in doing so would alter the state of the machine anyway.
- Deploying a remote forensic agent, such as EnCase Enterprise, **would require the suspect's credentials**, and functionality of this remote technique within the cloud is unknown.
- Simply viewing the target website is enough to confirm that the content is illegal, but it tells us nothing about who put it there.



Consider other possible sources of digital evidence in this case:

- Credit card payment information
- Cloud subscriber information
- Cloud provider access logs
- Cloud provider NetFlow logs,
- Virtual machine
- Cloud storage data.

Law enforcement can issue a search warrant to the cloud provider, which is adequate to compel the provider to provide any of this information that they possess. **The warrant specifies that the data returned be an "exact duplicate," ie bit by bit!!!!(But How?)**

A technician at the provider executes the search order from his or her workstation, copying data from the provider's infrastructure and verifying data integrity with hashes of the files.

Though the prosecution may call the technician to testify, we have no implicit guarantees of trust in the technician to collect the complete data, in the cloud infrastructure to produce the true data, nor in the technician's computer or tools used to collect the information correctly. **Nonetheless, the provider completes the request, and delivers the data to law enforcement.**

Let us say **that Polly had two terabytes of stored data.**

To transfer that quantity of data, the provider saves it to an external hard drive and delivers it to law enforcement by mail. In addition, the provider is able to produce

- *Account information*
- *10MB of access logs*
- *100MB of NetFlow records*
- *20GB virtual machine snapshot.*

After validating the integrity of the data, the forensic examiner is now charged with Analysis.

We would expect the forensic expert to identify the following that would aid in prosecution:

- Understand how the web service works, especially how it encrypts/decrypts data from storage
- Find keys to decrypt storage data, and use them to decrypt the data
- Confirm the presence of child pornography



This activity may take many man hours to analyze.

AccessData found that their Forensic Toolkit (FTK) product took 5.5 hours to process a 120GB hard drive fully on a top-of-the-line workstation and as long as 38.25 hours on a low-end workstation .

At that rate, 2TB of data could take 85 hours of processing time.

The provider may have returned individual files or large files containing “blobs” of binary data. In either case, it will become quickly evident that the data are encrypted. ***Tools like EnCase and Forensic Toolkit can analyze VMware data files but not snapshots which include suspended memory.***

We were already aware of illegal content, but not aware of the data owner. Timestamps or file metadata may prove useful, provided they are available and accurate. Evidence of the owner may be gleaned from NetFlow, timestamp, and potentially in the coding style of the website. We can safely assume that an IP can be found that points to Polly. **All of the forensic analysis is documented and presented to counsel.**



- Since raw bit-for-bit copies of hard drives were not provided, how do we know that the cloud provider provided a complete and authentic forensic copy of the data?
- Can the authenticity and integrity of the data be trusted?
- Can the cloud technician, his/her workstation and tools be verifiably trusted?
- Were the data located on one drive, or distributed over many? Where were the drives containing the data physically located?
- Who had access to the data, and how was access control enforced?
- Were the data co-mingled with other users' data?
- If data came from multiple systems, are the timestamps of these systems internally consistent? Can the date and time stamps be trusted, and compared with confidence?



Microsoft

Microsoft and Amazon declined to comment about their compliance abilities in this situation

amazon



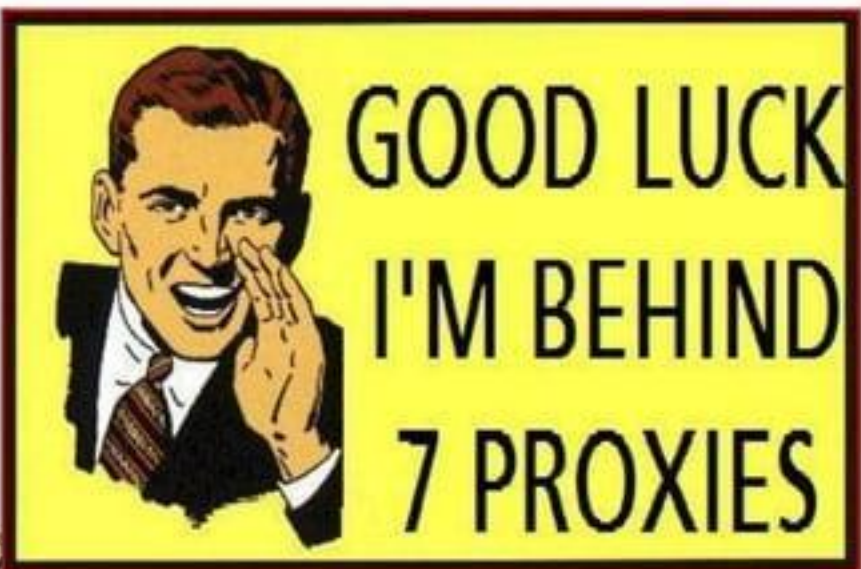
Whonix
Anonymous Operating System



Antiforensics

All of those techniques, tips and «methodologies» that may be able to slow down and/or «stop» the finding for digital evidences.

«Cloud» is *by default* an Antiforensics methodology (at least, it gives us tough times!!! ;)



REFERENCE MATERIAL

Whites reference : Josiah Dykstra & Alan T Sherman

At

dykstra@umbc.edu

sherman@umbc.edu

I am at

anupam@blumail.org

And blog at

www.anupriti.blogspot.com



Thank You